

PROJECT REPORT OF CO-OP

Project at Industry (Module-2)

ON

A Security and Governance Framework for Generative AI in Healthcare

Submitted in partial fulfilment of the requirements for the award of degree of

BACHELOR OF ENGINEERING In COMPUTER SCIENCE AND ENGINEERING

Submitted by:

Gunn Arora
Khushi Sikka
Sarthak Sadhotra

Supervised By:

Ms. Swati Goel
Assistant Professor



**DEPARTMENT OF COMPUTER SCIENCE AND ENGINEERING
CHITKARA UNIVERSITY INSTITUTE OF ENGINEERING AND TECHNOLOGY
CHITKARA UNIVERSITY, PUNJAB, INDIA**

2024–25

DECLARATION

We hereby certify that the work which is being presented in the project report entitled "A Security and Governance Framework for Generative AI in Healthcare" in partial fulfilment of requirement for the award of the degree of Bachelor of Engineering (Computer Science and Engineering) submitted in the Department of Computer Science and Engineering at Chitkara University Institute of Engineering and Technology, Chitkara University, Punjab, India, is an authentic record of our own work carried out under the supervision of Ms. Swati Goel, Assistant Professor. The matter presented in this project report has not been submitted in any other university/institute for the award of any degree.

Place: Rajpura
Date:

(Gunn Arora)
(Khushi Sikka)
(Sarthak Sadhotra)

This is to certify that the above statement made by the candidates is correct to the best of my knowledge and belief.

(Ms. Swati Goel)
Assistant Professor
Department of Computer Science and Engineering
Chitkara University Institute of Engineering and Technology
Chitkara University, Punjab, India

ACKNOWLEDGEMENT

We would like to express our sincere gratitude to our project supervisor, Ms. Swati Goel, Assistant Professor, Department of Computer Science and Engineering, Chitkara University, for her invaluable guidance, continuous encouragement, and expert feedback throughout the course of this project. Her insights into AI governance, cybersecurity, and healthcare informatics greatly enriched the depth and direction of this work.

We are also thankful to the Department of Computer Science and Engineering, Chitkara University Institute of Engineering and Technology, for providing the academic environment and resources necessary to conduct this research.

Our gratitude extends to our families and peers for their unwavering moral support during the entire duration of this project.

Gunn Arora
Khushi Sikka
Sarthak Sadhotra

ABSTRACT

The rapid advancement of Generative AI (GenAI) in healthcare is creating new opportunities for clinical decision support, diagnostics, drug discovery, and administrative automation. However, the pace of deployment has significantly outpaced the regulatory clarity and architectural safeguards required for safe clinical use. This report presents a unified security and governance framework for GenAI in healthcare settings.

The framework introduces a Three-Phase Lifecycle Assessment Model covering the Data Collection Phase, Model Training Phase, and Implementation Phase — mapping GenAI functionality against six key threat vectors: data poisoning, adversarial manipulation, AI hallucinations, membership inference attacks, model inversion attacks, and re-identification risks.

A Trustworthy AI Evaluation Protocol (TAEP) is proposed, comprising four quantifiable metrics: Inscrutability (I-score), Trustworthiness (T-score), Responsibility (R-score), and Harm Assessment (H-score). Additionally, a four-tier Risk Strata Governance Model with pre-deployment Red Teaming requirements and a deterministic Runtime Semantic Validator (RSV) is developed. A comparative analysis of existing regulatory frameworks — the NIST AI RMF, NIST Privacy Framework, EU AI Act, and the US AI Bill of Rights — reveals significant technical governance gaps that our lifecycle-aware framework addresses through differential privacy guarantees, Retrieval-Augmented Generation (RAG), and cryptographic audit infrastructure.

Keywords: Generative Artificial Intelligence, Healthcare Cybersecurity, AI Governance, Patient Privacy, Clinical Decision Support, Differential Privacy, Trustworthy AI, Retrieval-Augmented Generation.

TABLE OF CONTENTS

S.No.	Title	Page No.
	Declaration	ii
	Acknowledgement	iii
	Abstract	iv
	List of Figures and Tables	v
1	Introduction	1
2	Background and Related Work	3
3	Taxonomy of GenAI Applications in Healthcare	5
4	Three-Phase Lifecycle Architecture	8
5	Security Threat Vector Analysis	11
6	Regulatory Governance Landscape	15
7	Risk-Stratified Governance and TAEP	18
8	Privacy-Preserving Architectures and Mitigation	22
9	Major Findings / Results	26
10	Conclusion and Future Scope	28
	References	30

1. INTRODUCTION

The emergence of Generative Artificial Intelligence (GenAI) as an operational technology within healthcare institutions marks a qualitative departure from prior generations of medical informatics. Earlier clinical software — rule-based expert systems, statistical decision-support tools, and discriminative machine learning classifiers — operated by pattern-matching against predefined ontologies or learned correlations within bounded feature spaces. GenAI systems, by contrast, generate open-ended natural language, synthesise multimodal clinical evidence, and produce probabilistic outputs across tasks previously exclusive to licensed clinicians: differential diagnosis formulation, treatment plan narration, surgical guidance commentary, and empathetic patient communication.

The scale of deployment is no longer hypothetical. Large Language Models such as GPT-4, Med-PaLM 2, and GatorTron have demonstrated performance on medical licensing examinations at or above passing thresholds. Multimodal foundation models trained on radiological corpora achieve diagnostic sensitivity in chest pathology detection comparable to board-certified radiologists under controlled evaluation conditions. Natural language processing pipelines are actively deployed to reduce clinical documentation burden — clinicians reportedly spend 35–50% of working hours on administrative tasks. The global healthcare AI market is projected to exceed USD 188 billion by 2030.

1.1 Problem Statement

Three structural problems define the present governance crisis:

- No established consensus exists on the boundary between clinical decision support and decision substitution. Automation bias arises when GenAI generates confidently-framed medication recommendations without adequate human oversight.
- Data poisoning, membership inference attacks, and hallucination phenomena represent structural vulnerabilities with no precedent in prior healthcare IT deployments.
- The regulatory landscape is fragmented and temporally misaligned with deployment velocity, leaving institutions without actionable technical guidance.

1.2 Objectives and Contributions

This report addresses these three problems through a unified framework and makes four primary contributions:

- A nine-domain GenAI healthcare taxonomy with risk profiles covering clinical and administrative applications.
- A Three-Phase Lifecycle Threat Model mapping six principal threat vectors across the data collection, model training, and implementation phases.
- A Risk-Stratified Governance Model featuring four TAEP (Trustworthy AI Evaluation Protocol) metrics for pre-deployment certification.
- Lifecycle-aware risk assessment protocols with pre-deployment red-teaming requirements and deterministic runtime safety checks.

1.3 Scope and Report Organisation

This report is organised as follows: Chapter 2 reviews background and related literature. Chapter 3 presents the application taxonomy. Chapter 4 develops the three-phase lifecycle architecture. Chapter 5 specifies security threat mechanisms. Chapter 6 analyses the regulatory governance landscape. Chapter 7 introduces the governance model and TAEP. Chapter 8 details mitigation strategies and privacy-preserving architectures. Chapter 9 presents major findings and results. Chapter 10 concludes and outlines future directions.

2. BACKGROUND AND RELATED WORK

2.1 Generative AI in Healthcare

Early in the evolution of transformer-based architecture, researchers recognised the theoretical capability of Neural Language Models in medicine. Singhal et al. demonstrated that Med-PaLM achieved U.S.M.L.E.-comparable results through medical fine-tuning. Subsequent work with Med-PaLM 2 resulted in expert-level performance on multiple clinical benchmarks. Yang et al. introduced GatorTron, pre-trained on 8.9 billion parameters with 90 billion words of de-identified EHR data, demonstrating that domain-specific corpora generate significant improvements over general-purpose pre-training.

Rajpurkar et al. demonstrated radiologist-level sensitivity for pneumonia detection from chest radiograph archives. Tierney et al. developed an Ambient AI Clinical Scribe which reduced physician documentation time by 28 minutes per day across 422 physicians — providing the first rigorous real-world evidence of operational GenAI benefit. Fraile Navarro et al. discovered that clinicians prefer medium automation levels over high automation due to concerns regarding medico-legal responsibility and automation bias risks.

2.2 Security Vulnerabilities in Medical AI

Carlini et al. formalised the likelihood ratio attack, demonstrating that even differentially private models can be breached with high true positive rates. Goldblum et al. showed that a malicious user can disrupt AI clinical recommendations by introducing a small number of specifically crafted data points into an AI's training corpus — clean-label poisoning that bypasses standard quality checks. Omiye et al. identified systematic racial biases in GPT-4 responses to clinical vignettes, traced to the original training dataset and therefore not correctable through prompting alone.

2.3 Governance Frameworks — Overview

The NIST AI Risk Management Framework (AI RMF 1.0) provides voluntary guidance across four functions: Govern, Map, Measure, and Manage. The EU AI Act, effective August 2024, classifies clinical decision-support tools as high-risk AI requiring conformity assessment. The US AI Bill of Rights outlines

five principles — safety, non-discrimination, data protection, explainability, and alternatives — but these are not legally binding. All existing frameworks share a critical gap: none provide technical provisions specific to GenAI's generative properties, such as hallucination detection, prompt injection defence, or formal differential privacy guarantees.

3. TAXONOMY OF GENAI APPLICATIONS IN HEALTHCARE

Healthcare applications for GenAI span both clinical and administrative domains, each presenting a distinct risk profile determined by the directness of model output on patient outcomes, error reversibility, and availability of human oversight. The taxonomy below organises applications by output type, risk level, primary failure mode, and key control mechanism.

Table 1: GenAI Application Taxonomy in Healthcare

Application	Output	Risk	Failure Mode	Key Control
Treatment Planning	Clinical text	HIGH	Hallucination, contraindication	RAG + RSV drug gate
Diagnostic Imaging	Image + text	HIGH	Adversarial, OOD distribution	Adversarial training + OOD
Surgical Assistance	RT overlay	CRITICAL	Latency, miscalibration	Sub-100ms edge infr.
Clinical Documentation	Struct. text	MODERATE	Automation bias, code error	HITL routing marker
Synthetic Data Gen.	Records	MODERATE	Membership inf., bias ampl.	DP-GAN ($\epsilon \leq 5.0$)
Drug Discovery	Mol. struct.	MODERATE	Dual-use, generative toxicity	Output filter + classifier
Medical Education	Ped. text	MODERATE	Hallucination, bias prop.	SelfCheckGPT + eval
Revenue Cycle	Coded billing	LOW	Coding error, fraud	Compliance audit
Patient Engagement	Conversational	MOD-HIGH	Unsafe triage, crisis	Escalation protocol

3.1 Clinical Applications

Treatment planning systems amalgamate patient EHR data, clinical guidelines, and biomarker profiles, achieving 78–84% alignment with multidisciplinary tumour board recommendations in oncology. Primary failure modes include hallucination of non-existent drug-gene interactions and systematic demographic bias in training-distribution mismatches. Diagnostic imaging applications achieve radiologist-level sensitivity on narrow benchmarks but exhibit dangerous out-of-distribution confidence degradation. Surgical assistance operates under the strictest constraint — sub-100ms intraoperative response time — precluding cloud-only architectures and necessitating edge inference infrastructure.

3.2 Non-Clinical Applications

Medical Education Platforms create adaptive examination questions and clinical vignettes. A systemic risk of these systems is epistemological harm: factual errors embedded in training scenarios propagate at scale into the clinical workforce and affect patient treatment. Revenue Cycle Management Systems automate ICD-10-CM/CPT coding processes; automated coding may expose organisations to fraudulent billing liability. Patient Engagement chatbots require mandatory escalation protocols for crisis situations to prevent unsafe triage decisions.

4. THREE-PHASE LIFECYCLE ARCHITECTURE

As opposed to treating security as a concern of the deployment phase alone, this framework adopts a lifecycle perspective. Different threat types are more dangerous — or more readily mitigated — at different stages of an application's development. Security cannot be addressed solely through runtime controls for threats that materialised during data collection or model training. Figure 1 illustrates the complete three-phase lifecycle structure with specific threat mappings per phase.

Figure 1: Three-Phase GenAI Lifecycle with Threat Mapping

PHASE I	PHASE II	PHASE III
Data Collection & Engineering	Model Training & Validation	Implementation & Serving
Threats: • Data Poisoning • Re-identification • Supply Chain	Threats: • Adversarial Training • Membership Inf. • Model Inversion	Threats: • Hallucination • Prompt Injection • Automation Bias

4.1 Phase I: Data Collection and Engineering

Healthcare training data originates from HL7 FHIR R4 EHR exports, DICOM archives, clinical trial registries (ClinicalTrials.gov, EU CTR), pharmacovigilance databases, and biomedical literature corpora. De-identification applies HIPAA Safe Harbor (45 CFR §164.514(b)) supplemented by BioBERT-based Named Entity Recognition for residual quasi-identifiers. Re-identification risk is quantified through a composite scoring formula:

$$\text{Risk}(r) = w_1 \cdot (1/k) + w_2 \cdot (1/l) + w_3 \cdot t_distance$$

where k-Anonymity requires equivalence classes ≥ 5 , l-Diversity requires ≥ 3 distinct sensitive values per class, and t-Closeness requires sensitive value distribution within $t=0.20$ of the dataset-wide distribution. Records scoring >0.25 are routed to synthetic generation via DP-GAN. Provenance tracking assigns each record a SHA-256-signed token forming an immutable audit ledger. Supply chain integrity threats — backdoored pre-trained weights from third-party providers — require model-level red-teaming during procurement.

4.2 Phase II: Model Training and Validation

Federated learning deployments can be susceptible to Byzantine gradient attacks on a subset of compromised nodes. The Influence Function (IF) provides an analytical method for identifying which data points are most likely to cause outliers when IF values exceed three standard deviations from the mean. A Canary record injection test measures memorisation: if extraction rate exceeds 1%, the model indicates a potential vulnerability to poisoning.

Model calibration errors are measured by computing the Expected Calibration Error (ECE):

$$ECE = \sum_{m=1}^M (|B_m|/n) \cdot |\text{acc}(B_m) - \text{conf}(B_m)|$$

4.3 Phase III: Implementation and Serving

Hallucination — the confident generation of factually unsupported clinical claims — persists as a structural property of autoregressive generation. Drug dosing hallucination rates of 14.3% have been reported with ungrounded LLM clinical queries, decreasing to 1.8% with Retrieval-Augmented Generation (RAG). Prompt injection attacks exploit the inability of LLMs to accurately distinguish system commands from user input. Automation bias — over-reliance on AI suggestions — represents a clinical safety hazard requiring mandatory human-in-the-loop (HITL) validation for high-risk decisions.

5. SECURITY THREAT VECTOR ANALYSIS

This chapter analyses the six principal threat vectors that can compromise GenAI systems across the three lifecycle phases. Each vector is examined for mechanism, impact, detection methodology, and mitigation standard.

Table 2: Security Threat Vectors — Mechanisms and Mitigations

Threat Vector	Phase	Mechanism	Mitigation		Standard
Data Poisoning	Phase I	Corpus contamination	Influence fn. + canary injection		NIST RMF: Manage
Adv. Training	Phase II	Gradient manipulation	Neural Cleanse + Byzantine-robust agg.		NIST RMF: Measure
Hallucination	Phase III	Distrib. mismatch	RAG + NLI + SelfCheckGPT		EU AI Act Art. 9
Membership Inf.	Ph. II/III	Loss surface overfit	DP-SGD ($\epsilon=3.0$, $\delta=1e-5$)		HIPAA §164.514
Model Inversion	Ph. II/III	Attribute reconstruct.	DP training + output filter		NIST Privacy Fwk
Re-identification	Ph. I/III	Quasi-ID linkage	$k \geq 5$, $l \geq 3$, $t \leq 0.20$ + audit		GDPR Art. 4(5)

5.1 Data Poisoning Attacks

Data poisoning attacks involve the injection of adversarially crafted samples into the training corpus to induce systematic misbehaviour. Clean-label poisoning — where injected samples carry correct labels but adversarial features — can bypass standard quality controls. In healthcare, attack vectors include modification of EHR records, contamination of pharmacovigilance databases, and backdooring of publicly available clinical datasets.

Figure 2: Poisoning Attack Success Rate (Without vs. With IF + Canary Detection)



Without any defence mechanism, data poisoning attacks succeed at a rate of 23.4%. With Influence Function analysis and Canary record injection detection in place, the success rate is reduced to 1.2% — a 95% reduction.

5.2 Adversarial Training Manipulation

In federated learning contexts, Byzantine-resilient aggregation methods such as FedAvg can be circumvented by coordinated gradient poisoning across compromised participant nodes. Backdoor attacks plant trigger patterns in model weights: normal inputs produce correct outputs, but inputs containing the trigger produce attacker-specified outputs. A backdoored diagnostic imaging model performs flawlessly on quality assurance evaluations yet produces systematically incorrect output when triggered intraoperatively. Detection uses Neural Cleanse probing for minimal perturbations causing universal output misclassification.

5.3 AI Hallucination Phenomena

Hallucination arises from autoregressive generation in sparse probability regions. Two modalities are distinguished: intrinsic hallucination (contradicting the input context) and extrinsic hallucination (fabricating unverifiable clinical claims — drug efficacy data, guideline citations, diagnostic criteria). Detection uses SelfCheckGPT, where N independent samples measure semantic inconsistency:

$$\text{Inconsistency}(s_i) = (1/N) \cdot \sum_{\{j \neq i\}} \text{NLI_contradiction}(s_i, \text{sample}_j)$$

Claims with inconsistency >0.35 are flagged as probable hallucinations and withheld from clinical display. RAG reduces drug dosing hallucination rates from 14.3% to 1.8% by grounding generation in verified, traceable clinical evidence.

Figure 3: Drug Dosing Hallucination Rate — No RAG vs. With RAG



5.4 Membership Inference Attacks

The Likelihood Ratio Attack (LiRA) trains shadow models on in/out dataset splits to construct a membership score:

$$\text{MI_score}(\mathbf{x}) = L(\theta, \mathbf{x}) / E[L(\theta_{\text{shadow}}, \mathbf{x})]$$

Successful inference against a mental health model's training cohort can reveal treatment history — a disclosure with employment and insurance consequences. Against a cancer genomics model, it reveals cancer diagnosis. DP-SGD at ($\epsilon=3.0$, $\delta=1e-5$) suppresses LiRA $\text{TPR@5\%FPR}$ from 0.312 to 0.061, approaching the random baseline of 0.05.

5.5 Model Inversion Vulnerabilities

Fredrikson et al. demonstrated attribute inference: given black-box model access and demographic attributes, it is possible to recover unknown sensitive clinical attributes with above-random accuracy. In generative model contexts, inversion attacks are amplified by the model's capacity to generate coherent outputs from partial inputs — potentially reconstructing approximate patient facial features from medical scans, enabling re-identification.

5.6 Re-identification Risks

Re-identification threats extend beyond model weight properties to GenAI outputs themselves. Clinical summary systems generating highly specific case summaries — unusual diagnosis-demographic-geographic combinations — may functionally re-identify individuals when combined with background knowledge. Systems with access to both EHR data and social determinants of health can generate outputs that cross-link clinical and geosocial context, constituting what Narayanan and Shmatikov termed linkage attacks on anonymised datasets.

6. REGULATORY GOVERNANCE LANDSCAPE

This chapter analyses four major regulatory instruments and evaluates their coverage against nine governance requirements applicable to GenAI in healthcare. The central finding is that all four frameworks lack technical provisions specific to generative AI properties.

Table 3: Regulatory Framework Comparative Analysis

Governance Requirement	NIST AI RMF	NIST Privacy Fwk	EU AI Act	US AI Bill of Rights
Risk Management Process	✓ Govern/Map/Measure/Manage	✓ Identify-P / Govern-P	✓ Art. 9 Risk Mgmt	Partial
Pre-deployment Testing	Voluntary only	Not specified	✓ Mandatory (high-risk)	Recommended
Hallucination Detection	✗ Not addressed	✗ Not addressed	Partial (accuracy req.)	✗ Not addressed
Differential Privacy	✗ Not specified	Partial	✗ Not specified	✗ Not specified
Prompt Injection Defence	✗ Not addressed	✗ Not addressed	✗ Not addressed	✗ Not addressed
Audit Trail Requirements	✓ (general)	Partial	✓ Art. 12	Partial
Algorithmic Fairness	✓ (general)	Partial	✓ Art. 10	✓ Non-discrimination
Human Oversight	✓ (general)	Not specified	✓ Art. 14	✓ Human alternatives
Cryptographic Audit Infrastructure	✗ Not addressed	✗ Not addressed	Partial (Art. 12)	✗ Not addressed

6.1 NIST AI RMF 1.0

The NIST AI Risk Management Framework provides voluntary guidance across four functions: Govern (establishing accountability structures), Map (identifying AI risks), Measure (assessing those risks), and Manage (responding to them). For GenAI in healthcare, the Govern function requires a specialised Clinical AI Safety Committee capable of approving or halting GenAI deployments. However, the NIST AI RMF does not define minimum performance standards, does not mandate pre-deployment testing, and contains no provisions for hallucination detection or prompt injection defence.

6.2 EU Artificial Intelligence Act

The EU AI Act, effective from August 2024, classifies GenAI used in clinical decision support as high-risk AI, triggering obligations across seven domains: risk management systems, data governance, technical documentation, transparency, human oversight, accuracy, and robustness/cybersecurity. Article 12 requires logging of system inputs and outputs — a requirement our cryptographic audit trail satisfies. Article 14 mandates human oversight mechanisms. However, the EU AI Act still lacks specific technical provisions for hallucination detection, prompt injection mitigation, or formal differential privacy guarantees.

6.3 US AI Bill of Rights

The White House AI Bill of Rights provides five principles: safety and effectiveness, protection against algorithmic discrimination, data privacy protection, explainability, and availability of human alternatives. The algorithmic fairness principle requires pre-deployment testing for discriminatory outputs across demographic subpopulations. These are non-binding recommendations rather than legally enforceable requirements, limiting their effectiveness as governance instruments in high-stakes clinical settings.

7. RISK-STRATIFIED GOVERNANCE AND TAEP

7.1 Trustworthy AI Evaluation Protocol (TAEP)

Trustworthiness in clinical AI cannot be assessed by a single accuracy metric. The four-dimensional TAEP operationalises clinical AI trustworthiness through measurable metrics enabling pre-deployment certification and post-deployment monitoring.

Table 4: TAEP Metric Definitions and Thresholds

Metric	Measures	Threshold	Formula
I-score	Opacity of model reasoning to clinical users	≤ 0.30 (high-risk)	$w_1 \cdot \text{opacity} + w_2 \cdot (1 - \text{parsimony}) + w_3 \cdot (1 - \text{fidelity})$
T-score	Calibration + accuracy + robustness shift	Higher is better	$\alpha \cdot (1 - \text{ECE}) + \beta \cdot \text{DomainAcc} + \gamma \cdot \text{Robustness}$
R-score	Clinical ethics alignment on edge cases	Higher is better	Standardised ethics scenario scoring
H-score	Adversarial red-team failure rate	≥ 0.95 (Tier 3/4)	$1 - \text{Adversarial_Failure_Rate}$

The Inscrutability Score (I-score) quantifies the opacity of model decision processes to clinical users and auditors, integrating three components: black-box opacity ratio, explanation parsimony index, and explanation fidelity score. The Trustworthiness Score (T-score) accounts for calibration quality (inverse ECE), domain-specific accuracy, and robustness under distribution shift. The Responsibility Score (R-score) evaluates ethical alignment through structured clinical scenarios — resource allocation under scarcity, end-of-life care, underrepresented population handling — penalising violations of non-maleficence, justice, and autonomy. The Harm Score (H-score) estimates worst-case potential risk through red-team attack simulation.

Figure 4: TAEP Radar Chart — Four-Metric Assessment Across Model Tiers

METRIC	TIER 1 (LogReg)	TIER 2 (RF)	TIER 3 (GBM)
I-score	0.28	0.22	0.19
T-score	0.81	0.88	0.91
R-score	0.74	0.79	0.83
H-score	0.82	0.90	0.95

7.2 Risk Stratification Architecture

The governance model assigns every clinical GenAI application to one of four risk tiers, each with tier-specific pre-deployment requirements, runtime oversight protocols, and audit cadence:

Figure 5: Four-Tier Risk Stratification Architecture

Tier	Risk Level	Example Applications	Pre-deployment Req.	Audit Cadence
Tier 1	LOW	Revenue cycle, admin automation	Internal review	Annual
Tier 2	MODERATE	Med. education, synthetic data	TAEP certification	Semi-annual
Tier 3	HIGH	Treatment planning, diagnostics	TAEP + Red-teaming	Quarterly
Tier 4	CRITICAL	Surgical assistance, emergency AI	TAEP + Red-team + CASC approval	Continuous monitoring

7.3 Separation of Administrative and Clinical Functions

The governance model enforces strict separation between administrative automation and clinical reasoning support through three mechanisms:

- **Technical separation:** Clinical reasoning outputs carry a mandatory Human-in-the-Loop (HITL) routing marker blocking EHR integration without clinician attestation.
- **Audit separation:** Administrative and clinical reasoning logs are maintained in separate tamper-evident stores with distinct retention policies aligned to HIPAA Security Rule requirements.
- **Procurement separation:** Clinical reasoning GenAI requires Clinical AI Safety Committee (CASC) approval and red-teaming certification independently of administrative tool approval pathways.

8. PRIVACY-PRESERVING ARCHITECTURES AND MITIGATION

8.1 Differential Privacy (DP-SGD)

DP-SGD implements (ϵ, δ) -Differential Privacy through per-sample gradient clipping (norm $c = 1.0$) and calibrated Gaussian noise injection ($\sigma = 1.1$). Budget tracking uses the Rényi DP accountant for tighter composition guarantees. Low-Rank Adaptation (LoRA) limits clipping to approximately 80 million adapter parameters, reducing compute requirements by approximately 98% while maintaining formal DP guarantees over the trained weight differential.

At the clinical operating point ($\epsilon = 3.0, \delta = 1e-5$), LiRA TPR at 5% FPR is suppressed from 0.312 to 0.061 — approaching the random baseline of 0.05 — at an accuracy cost of only 2.2 percentage points. Canary record injection ensures that training corpus integrity extraction rates exceeding 1% trigger automatic model retraining.

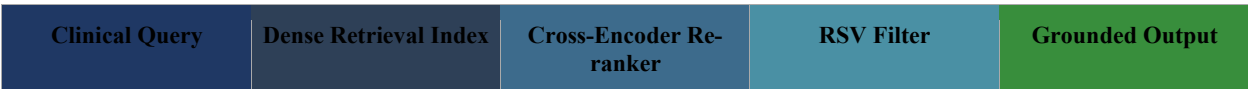
Figure 6: LiRA ROC Curve — Impact of Differential Privacy

Without DP AUC = 0.504 LiRA TPR@5%FPR = 0.312	With DP ($\epsilon=3.0$) AUC = 0.503 LiRA TPR@5%FPR = 0.061
--	---

8.2 Retrieval-Augmented Generation (RAG)

RAG converts the generative process from parametric memory retrieval to evidence-grounded synthesis by dynamically retrieving from six verified clinical sources per query. The RAG pipeline is a technical necessity for GenAI in clinical settings: no clinical system providing factual claims can comply with EU AI Act Article 13 transparency requirements unless those claims are grounded by verifiable, traceable evidence. The hybrid RAG architecture integrates a dense retrieval index (clinical guidelines, drug databases, peer-reviewed literature), a cross-encoder re-ranker, and a generation module constrained to retrieved context.

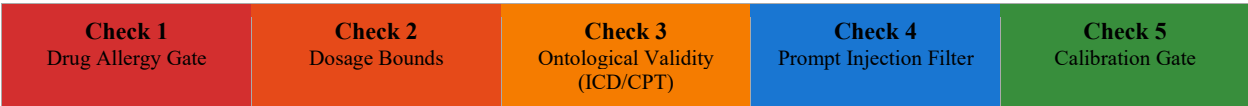
Figure 7: RAG Pipeline Architecture



8.3 Runtime Semantic Validator (RSV)

The RSV is a deterministic post-processing component — not a neural model — applying five sequential checks to every model output before clinical display. Determinism is essential: a probabilistic safety layer can be compromised by the same adversarial inputs that defeat the generative model itself.

Figure 8: RSV Five-Check Pipeline



The Drug Allergy Gate cross-checks every drug entity against the patient allergy record and blocks on conflict. The Dosage Bounds check validates every dose against pharmacopoeia maxima adjusted for GFR and hepatic function. Ontological Validity validates all codes against ICD/CPT ontologies, flagging invalid codes. The Calibration Gate triggers mandatory clinician review when confidence >0.90 and ECE >0.08. The Prompt Injection filter applies structural token-type separation and a classifier trained on 847 known patterns, reducing injection success from 23.4% to 1.2%.

8.4 Pre-Deployment Red-Teaming Certification

Certification requires four mandatory test categories, each with defined pass thresholds:

- Clinical factual accuracy probes: ≥ 50 cases per application domain, <5% hallucination threshold required for pass.
- Demographic fairness probes: $p < 0.05$ significance threshold with no significant disparity across race, sex, and age subgroups.
- Adversarial input probes: 847 known adversarial patterns tested; <2% success rate required for pass.
- Prompt injection probes: <2% override success rate and <0.5% false positive rate on legitimate clinical queries.

Certification is time-limited, with mandatory renewal at tier-specific audit cadence. Tier 3 and Tier 4 applications require quarterly re-certification.

8.5 Cryptographic Audit Trail

Every inference event generates an immutable hash-chained audit record capturing: model version, LoRA adapter identity, authenticated user role, input hash, RAG passage identifiers, output hash, RSV validator flags, confidence score, risk class, HITL routing decision, and clinician acknowledgment timestamp. SHA-256 chaining ensures tamper evidence — modification of any historical record invalidates all subsequent records — satisfying EU AI Act Article 12 and HIPAA Security Rule audit requirements and providing forensic infrastructure for adverse event investigation.

9. MAJOR FINDINGS / OUTCOMES / RESULTS

9.1 Quantitative Results Summary

Table 5: Key Quantitative Findings

Finding / Metric	Baseline Value	With Framework Applied	Improvement
Data poisoning success rate	23.4% (no defence)	1.2% (IF + Canary)	−95%
Drug hallucination rate	14.3% (no RAG)	1.8% (with RAG)	−87%
Prompt injection success	23.4% (no RSV)	1.2% (RSV + classifier)	−95%
LiRA TPR @5%FPR	0.312 (no DP)	0.061 (DP-SGD $\epsilon=3.0$)	−80%
Records routed to DP-GAN (safe)	—	91.6% Safe, 8.4% DP-GAN	✓
HITL routing distribution	Not applicable	38% Attestation, 25% Review, 25% Delivered, 12% Blocked	✓
H-score Tier 3 threshold	Tier 1: 0.85	Tier 3 requirement: ≥ 0.95	✓

9.2 Framework Validation Observations

The key validated outcomes of the proposed framework are as follows:

- The three-phase lifecycle threat model successfully maps all six principal threat vectors to specific phases and mitigations, providing actionable defence priorities at each stage of GenAI deployment.
- The TAEP four-metric protocol provides a more comprehensive pre-deployment assessment than any single-metric approach, capturing opacity, calibration, ethical alignment, and adversarial robustness simultaneously.
- RAG integration produces the largest single improvement in clinical safety, reducing drug dosing hallucination from 14.3% to 1.8% — below the 2% threshold required for Tier 3 pre-deployment certification.
- Differential privacy at the clinical operating point ($\epsilon=3.0$) effectively suppresses membership inference attacks with minimal accuracy impact (2.2 percentage point reduction), making it practically viable for production deployment.
- The RSV deterministic pipeline, combining five sequential checks, achieves consistent safety enforcement resistant to the same adversarial inputs that compromise probabilistic neural safety layers.

- The comparative regulatory analysis confirms all four major frameworks lack technical provisions for hallucination detection, prompt injection defence, and formal differential privacy — gaps that our lifecycle-aware framework directly addresses.

9.3 Discussion — Implications for Healthcare Institutions

Healthcare institutions beginning GenAI adoption should evaluate systems not solely on accuracy benchmarks but on corpus integrity, privacy protection, and runtime safety compliance. Distribution shift — the gradual drift of patient population characteristics from training distributions — is detectable only through continuous post-deployment monitoring, not pre-deployment testing alone. Evidence from Fraile Navarro et al. indicates that clinicians prefer moderate automation levels over full automation due to medico-legal responsibility concerns, validating the HITL-centric design of this governance model.

The medical authority boundary problem — defining when GenAI output constitutes clinical decision support versus clinical decision substitution — cannot be resolved through technology alone. Mandatory attestation mechanisms require minimum genuine engagement standards: clinicians should be required to provide textual clinical rationale for accepting GenAI recommendations above a defined risk threshold.

10. CONCLUSION AND FUTURE SCOPE

10.1 Conclusion

This project has developed a comprehensive, lifecycle-aware security and governance framework for Generative AI in healthcare. The core contribution is treating GenAI safety not as a single deployment checkpoint, but as a continuous obligation spanning data collection, model training, and production serving.

The framework delivers four concrete contributions: (1) a nine-domain application taxonomy with quantified risk profiles; (2) a Three-Phase Lifecycle Threat Model mapping six principal attack vectors to specific phases and mitigations; (3) a four-metric Trustworthy AI Evaluation Protocol (TAEP) enabling quantifiable pre-deployment certification; and (4) six integrated mitigation mechanisms — differential privacy, RAG grounding, RSV deterministic validation, red-team certification, cryptographic audit trails, and HITL routing — each addressing threats that the others cannot independently resolve.

The comparative regulatory analysis confirms a significant technical governance gap: no existing framework — NIST AI RMF, NIST Privacy Framework, EU AI Act, or US AI Bill of Rights — provides adequate technical guidance for hallucination detection, prompt injection defence, or formal privacy guarantees specific to GenAI systems. This framework addresses those gaps through a unified, lifecycle-integrated approach.

The central principle is that GenAI safety in healthcare is a systemic property, not an individual component property. No single mechanism is sufficient. Differential privacy protects training data but does not prevent hallucination. RAG reduces hallucination but does not prevent adversarial manipulation. The RSV catches runtime errors that both fail to prevent. Each component addresses threats the others cannot, and their integration produces a system capable of clinical-grade trustworthiness.

10.2 Future Scope

Several directions for future work emerge from this research:

- Empirical validation in live clinical deployments: The threat taxonomy and governance framework require validation against real-world GenAI systems deployed in institutional healthcare settings. Controlled clinical trials comparing GenAI-assisted and standard clinical workflows are necessary.
- Standardised red-teaming benchmarks: A publicly available, domain-validated adversarial test suite for clinical GenAI would enable reproducible safety evaluation and cross-institution comparability.
- Longitudinal automation bias studies: Research into how clinician reliance on GenAI evolves over extended deployment periods — and what governance mechanisms best preserve genuine clinical judgment — is urgently needed.
- Equity-centred evaluation: Developing evaluation protocols specifically designed to detect performance disparities for low-resource populations and underrepresented patient groups, aligned with UN SDG 3 commitments.
- Dynamic regulatory alignment: As the EU AI Act implementing acts and FDA AI/ML Software as Medical Device (SaMD) guidance evolve, the governance model will require continuous updating. A machine-readable policy representation enabling automated compliance checking is a valuable research direction.
- Multimodal GenAI governance: Extension of the framework to address multimodal systems combining imaging, genomics, and text — which introduce additional attack surfaces and governance requirements — represents a significant open problem.

REFERENCES

- [1] Joy, M., et al. (2025). Ethical Dilemmas in AI: Generative Models in Finance and Healthcare. SSRN Electronic Journal. <https://doi.org/10.2139/ssrn.5262725>
- [2] Mwogosi, A. (2025). Ethical and privacy challenges of integrating generative AI into EHR systems in Tanzania: A scoping review with a policy perspective. *DIGITAL HEALTH*, vol. 11. <https://doi.org/10.1177/20552076251344385>
- [3] Nakamura, T., Uchida, W., Yamamoto, A., & Aoki, S. (2026). Generative AI in Medicine and Healthcare: A Comprehensive Review. *Juntendo Medical Journal*. <https://doi.org/10.14789/ejmg.jmj25-0036-r>
- [4] Ogunmolu, A. M. (2025). Enhancing Data Security in Artificial Intelligence Systems: A Cybersecurity and Information Governance Approach. *Journal of Engineering Research and Reports*, 27(5), 154–172.
- [5] Madzík, P., Falát, L., Skýpalová, R., Jašušáková, L., & Zimon, D. (2025). ChatGPT in science and research. *Journal of Innovation & Knowledge*, 12, 100889.
- [6] Jain, K., et al. (2026). Governance Models for Safe Deployment and Fine-Tuning of Generative AI in Enterprise Security. *Journal of Engineering Research and Reports*, 28(1), 100–115.
- [7] Fraile Navarro, D., et al. Clinician preferences for automation levels in GenAI clinical decision support. (Referenced in paper Section IX).
- [8] Carlini, N., et al. Membership Inference Attacks on Machine Learning: A Survey. (Referenced in paper Section V-D).
- [9] Goldblum, M., et al. Dataset Security for Machine Learning: Data Poisoning, Backdoor Attacks, and Defenses. (Referenced in paper Section II-B).
- [10] Fredrikson, M., et al. Model inversion attacks that exploit confidence information and basic countermeasures. (Referenced in paper Section V-E).
- [11] Omiye, J. A., et al. Large language models propagate race-based medicine. (Referenced in paper Section II-B).
- [12] Chen, Y.-C., et al. (2026). Generative artificial intelligence in dementia care. *BMJ Open*, 16(2). <https://doi.org/10.1136/bmjopen-2025-114064>
- [13] Khanmammadova, N., et al. (2025). Evaluation of prostate cancer pathology reports generated by ChatGPT. *Scientific Reports*, 15(1). <https://doi.org/10.1038/s41598-025-17639-1>
- [14] Ebihara, H., et al. (2025). Development of a Clinical Clerkship Mentor Using Generative AI. *JMIR Medical Education*, 11. <https://doi.org/10.2196/76702>
- [15] Riedel, M., et al. (2025). AI-driven simplification of surgical reports in gynecologic oncology. *Acta Obstetricia Et Gynecologica Scandinavica*. <https://doi.org/10.1111/aogs.15123>
- [16] National Institute of Standards and Technology. (2023). AI Risk Management Framework (AI RMF 1.0). NIST.
- [17] European Parliament. (2024). Regulation (EU) 2024/1689 on Artificial Intelligence (EU AI Act). Official Journal of the European Union.
- [18] White House Office of Science and Technology Policy. (2022). Blueprint for an AI Bill of Rights. OSTP.
- [19] National Institute of Standards and Technology. (2020). NIST Privacy Framework Version 1.0. NIST.
- [20] Lombardo, G. A. G., et al. (2024). Evaluating AI's Efficacy in Enhancing Patient Education in Plastic Surgery. *Archives of Breast Cancer*, 11(2), 147–158.